

From Alignment to Access Control: A Framework for GenAI Policy Enforcement

Nathalie Baracaldo
IBM Research

September 2026

Abstract

Generative AI (GenAI) applications have flourished enabling users to chat with large language models, and to create agents to act on their behalf for a variety of tasks. The pace of development of capabilities in this field is incredibly fast with security and safety taking a back seat. Unfortunately, the slower pace at which security and safety mechanisms have evolved has led to real incidents. Policy enables the definition of desirable behavior of applications, and for that reason, it is a cornerstone of making systems secure and compliant. *Policy* however means different things to different practitioners creating confusion and siloed solutions that are not adequate for compliance. This paper takes a tour of the good, the bad and the ugly when it comes to policy enforcement in GenAI applications. We propose a methodology to systematically analyze and dissect existing approaches to define and enforce policy found in the wild. Based on this principled analysis, we provide recommendations and call for action for the community to address.

This paper is a companion extension of USENIX Security 2026 Enigma talk titled *“From Alignment to Access Control: A Unified View of GenAI Policy Enforcement”* by the author *Nathalie Baracaldo*.

1 Introduction

With the fast evolution in capabilities of large language models (LLMs) a great amount of Generative AI (GenAI) applications have emerged in a variety of sectors including finance [5], vibe coding [85], information technology (IT) automation tasks [61], companion chat bots [21], among many others. Their power has enabled users to use agents to run workflows and tasks on behalf of users and organizations, alike. Without a doubt, the power of LLMs have opened a new era of opportunities [96, 103, 79].

At the same time, new incidents have impacted organizations and people in negative ways [46, 34]. We highlight two incidents that are different in nature. The first incident occurred while vibe coding, where a GenAI agent deleted a



Figure 1: Screenshot depicting vibe coding incident that resulted in a production database deletion [64].

production dataset despite receiving clear instructions not to make any changes [64] (Fig. 1). The second type of incidents took place when the interaction with LLMs led users to delusional thinking that caused them to endanger their lives or the lives of others [59, 74].

What do these incidents have in common? At first glance, not much. One is related to cybersecurity while the other one is related to psychosis generated by interacting with an LLM. However, after further inspection, the incidents do have one thing in common: they could have been prevented (or at least mitigated) if the right policies were defined and enforced. In the first incident, having adequate access control enforcement and in the second one, by steering the model away from sycophantic spirals. But, how should these policies be defined and enforced?

Before answering that question, let’s define what we mean by GenAI policy. The word “policy” itself carries radically different meanings across communities as illustrated by Fig. 2. Security practitioners think in terms of mandatory access controls and formal rule systems. Application developers treat policy as agent flow constraints and output validation. Policies can also contain service level agreements (SLAs) or other types of application level requirements, for example the minimum balance an account can have, or in other cases, user enrollment requirements. AI researchers grapple with softer, high-level behavioral norms: for example, maintaining a non-sycophantic tone, where even the definition of compliance is fuzzy. In the reinforcement learning jargon a machine learning model that has learned certain rules is referred to as *policy*.

As the list shows, even agreeing on what we mean by policy can be challenging. To understand this tension, let us analyze how different communities define and enforce policies in different ways. For the cybersecurity community, defining and enforcing policy is a cornerstone of the field with formal languages to specify policy and enforcement mechanisms with verifiable properties. Unlike conventional cybersecurity systems with well-defined enforcement boundaries, GenAI applications operate in a highly dynamic, probabilistic environment,

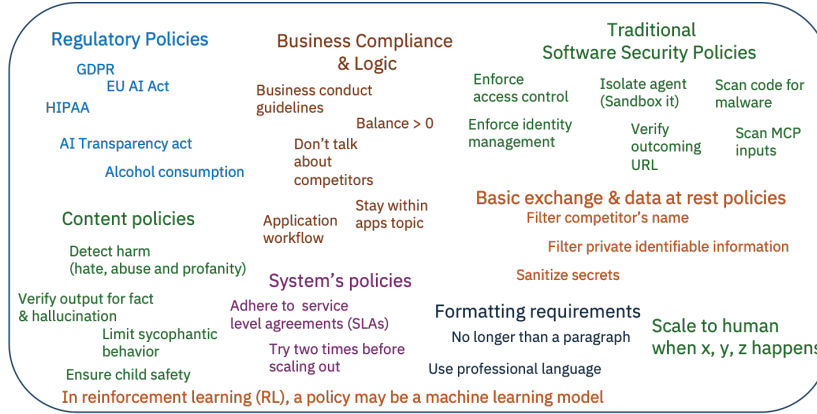


Figure 2: The word *policy* has a diverse set of meanings. A single GenAI application needs to be governed by multiple such policies. Discovering, specifying and enforcing such a diverse set of policies is an open challenge.

making policy enforcement a non-trivial, interdisciplinary challenge. The non-deterministic nature of GenAI makes it incredibly useful, but at the same time introduces a fundamentally new and evolving threat landscape where existing mechanisms fall short. Not all the desired policies can be defined and enforced in a deterministic fashion.

What’s more, with the evolution of the LLM capability, the possibility of specifying a policy in plain natural language has made it possible to define fuzzy policies that were un-enforceable in the past. This has led to a variety of novel approaches for policy enforcement that, as we will see, may generate a false sense of security and compliance.

In addition, different communities often operate in silos, producing enforcement approaches that are fragile, ad hoc, and critically, designed to handle only one policy at a time. Real enterprise GenAI applications, however, demand simultaneous compliance with multiple, overlapping policies across all these layers – a requirement today’s tools are not built for. Until the community addresses this fragmentation and acknowledges what solutions are problematic, true compliance in enterprise AI systems will remain an illusion.

In this paper, we face all these dichotomies to provide a much needed 360 view of the field. We propose a methodology to analyze state of the art approaches for policy specification and enforcement, and understand what defense in depth means for different deployments. Our analysis brings to light the necessity of having solutions that encompass a diverse set of policies in a single control plane to ensure governance.

Our **contributions** are as follows:

- *Tour of the Wild*: We survey what different communities of practitioners refer to as “policy”, what type of interactions they aim to govern and the mechanisms that have been proposed to enforce such policies.

- *A Framework to Dissect GenAI Policies:* Given the diverse set of approaches found in the wild, it is a cumbersome task to discern their appropriateness and establish commonalities. To close this gap, we propose a methodology to determine the appropriateness of competing policy enforcement mechanisms. The methodology dissects solutions based on three factors: policy definition, policy enforcement guarantees and stack enforcement. Our approach aims to help guide the community in the selection of the adequate policy enforcement mechanisms for a diverse set of policies applicable to GenAI applications.
- *Open Challenges and Call to Action:* Through this tour of the wild, we conclude that there is no single enforcement mechanism for GenAI policy today: policy is fragmented across model alignment, runtime guardrails, agent flow constraints, and access controls, with no unified view across layers. Some clearly flawed approaches are used out there. We conclude the paper by providing recommendations to avoid common pitfalls and discussing open challenges.

The rest of the paper takes a top-down approach starting by highlighting the trends in GenAI policies in the wild (Sec. 2) and presenting the proposed methodology to dissect them (Sec. 3). As we unfold different findings, we highlight takeaways of our analysis. We provide more information about existing approaches in Sec. 4. Finally, in Sec. 5, we conclude the paper by summarizing the recommendations and open challenges. We hope this work will enable the community to generate safer and compliant solutions.

2 Policies in the Wild

Policy is a somewhat fuzzy word that may mean different things to different audiences. This overloaded word results in difficult communication among communities and how they perceive and propose solutions for GenAI compliance. The diversity of policies is also due to the very diverse set of applications and users of LLM-based systems. We start by defining basic concepts and providing aggregated information of our survey findings. Detailed information about each approach is available in Section 4.

What is a GenAI Application? We use the term GenAI applications to refer to *agents* that use LLMs to complete tasks or chat bots such as HR or companion Chat bots [21] where an end user interacts with a LLM. Fig. 3 depicts a common architecture of a GenAI agent that interacts with a user or other agents. It has memory to store prior relevant information and interactions, and other tools to access and send email, browse the web, use datasets and many others. In this infrastructure, the amount of information flow and interaction needs to be governed by policies. But what policies?

What are common policies in the wild? We survey available policies in papers and frameworks available. Based on this survey, we grouped policies based on their semantics and showcase where they are applied in the agentic

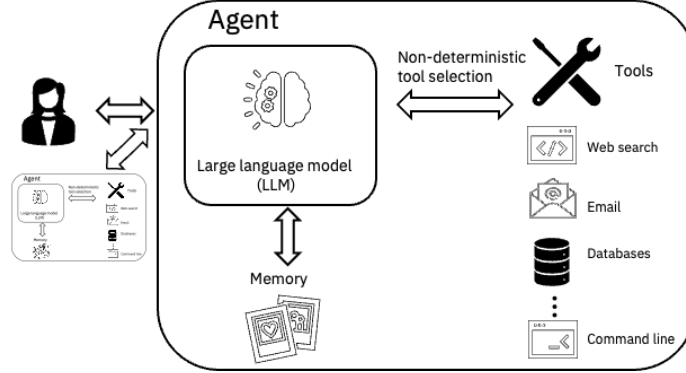


Figure 3: A typical GenAI agent

stack. Table 1 compiles a list of representative types of *policies* we found in the wild. The list is quite diverse and we broadly classify them in:

1. *Regulatory policies* such as GDPR [93], HIPAA [92] that are legal frameworks that oftentimes require the enforcement of multiple rules.
2. *Content and behavioral policies* that dictate the content that can be exchanged and the types of interactions a machine learning model can have. For example private identifiable information (PII) policies mostly require the removal of private information from prompts and assistant answers. Other policies in this category focus on detecting and stopping harms such as hateful speech, misinformation, bias, among others.
3. *Business compliance and logic* where a variety of rules specific to the application are defined. In this category, we see policies that dictate when a person may change their flight for free [105], or when someone is entitled to file an insurance claim for reimbursement [63, 38]. These are frequently embedded in prompts or application logic.
4. *Traditional Cybersecurity Policies* such as identity management, access control and specification of policies to filter out content or stop the access to different tools such as datasets, email, or Internet. In this category we see policies that specify if a tool should be invoked or not by for example scanning file content, looking for vulnerable software, etc.
5. *System Policies* where an agent or application should comply with a service level agreements (SLAs), or other deployment requirements [37].
6. *Policies related to the model specification* commonly used to define how LLMs will answer sensitive questions such as [9, 13, 47, 40]. In this category, the word policy is also used by the reinforcement learning community to mean the rules an agent uses to receive rewards. Interestingly this may

contain the rules themselves or a machine learning model that is assumed to have already learned the right set of rules.

In the rest of this paper, we refer to *policy* as a set of requirements that once specified can be enforced by a machine. This means that when we use the word policy, we refer to all the policies listed above except for the “regulatory policies” which require decomposition and cannot *currently* be directly enforced by a machine.

Policy Category	Examples
Regulatory Policies	GDPR EU AI Act HIPAA AI Transparency Act Right to be forgotten
Content & Behavioral Policies	Principle-based harm detectors (e.g., hate, abuse, profanity) [57, 78] Mitigate sycophantic interactions Guided conversation [84] Fact & hallucination control Alcohol consumption [13] Child safety (anthropomorphic, interaction and relational cues [33], prevent sexual abuse [2])
Model Specification	Alignment policies to define model specifications [13, 47, 9, 6, 98]
Business Compliance & Logic	Punctual application specific logic [105, 67, 50, 63] Business conduct guidelines [1] Don’t discuss competitors Enforce business constraints (balance > 0) Ensure app remains on topic Application workflow [61] Use polite business like tone
Traditional Cyber Security Policies	Identity management [54, 42, 26, 44] Traditional access control [104, 44, 54, 42, 36] Malware detection MCP file scanners, URL verification [54] Data flow policies [97] Apply secret detectors before storing data Filter private information and competitor names [56]
System Policies	Ensure service level agreements [100] Container deployment [37] Retry twice before scaling out deployment

Table 1: Policy means different things to different audiences. We compile a diverse set of policy categories that we found in the wild. GenAI applications typically need to enforce multiple policies simultaneously.

What are the targets of GenAI policies? Policies apply to a variety of components of the GenAI application as shown in Table 2. We classify them into *single-turn*, *multi-turn*, *tools*, *trace-based*, *harness* and *memory*. The first two columns show if a policy targets single and multi-turn interactions with models. As it can be seen, policies may apply to single prompt-answer interactions; a great number of guardrails are built to regulate those interactions. We also see that business compliance and logic policies tend to apply to the prompt-answer space. Tool interaction is also subject to a variety of policies mostly traditional cybersecurity ones. Other policies relate to traces of the agentic application that dictate how the application should behave (adequate order of operations). Policies may also need to be enforced at the harness level, for example, a container needs to be deployed only in a particular geography or data can only be stored in certain data centers. Finally, in the last column, we note that interestingly, policies related to *memory* mostly include contractual stipulations and restricting storage of private data.

What are the enforcement mechanisms? The enforcement mechanisms of these policies are quite diverse. At the same time, GenAI applications need to be governed by one or more policies that need to be enforced in different places in the stack. To reason about existing approaches and their suitability, in the next section, we propose a framework that helps design applications in a safer fashion.

	Single-turn	Multi-turn	Tools	Trace-based	Harness	Memory
PII Detectors	✓		✓			
Harm detectors, fact checking, hallucinations [84, 57, 78]	✓					
Sycophancy	✓	✓				
Filter competitors names	✓					
Secret detectors	✓		✓			
Code Safety	✓		✓			
OPA regex			✓			
URL verification			✓			
MCP file scanners [54]				✓		
Data flow policies [97]				✓	✓	
Traditional access control [104, 44, 54, 42]			✓			
Identity management [54, 42, 26, 44]			✓			
Flow-based policies [97]				✓	✓	
Punctual application specific logic [105, 67, 50, 63]	✓		✓			
Business conduct guidelines [1]	✓	✓	✓		✓	
General formatting requirements	✓					
Model alignment policy [47, 9, 98]	✓	✓				
Deployment [37]					✓	
Agentic memory [7, 76, 8]						✓

Table 2: Targets of GenAI policies

3 Proposed Approach to Dissect Policies

We now propose a methodology to dissect policies and their respective enforcement mechanisms to understand how they differ and what are their gaps with the objective of reducing the noise related to inappropriate enforcement proposals.

We dissect current approaches by analyzing the following dimensions:

1. **Policy Definition** can vary between *strict* and *fuzzy*. Strict policies are frequently specified using formal languages such as XACML. With the capability improvement of LLMs, it is possible to specify policies using natural language which oftentimes is less precise.
2. **Mechanism Enforceability** Policy enforcement mechanisms can be characterized based on the guarantee enforceability that they provide, which may fall in a spectrum between *soft* and *hard* enforceability. In one extreme, *hard* mechanisms are *deterministic* and often provide guarantees about their enforcement. Traditional cybersecurity solutions such as enforcing identity management, role-based access control, among others have been designed to have hard enforceability. In the other side of the spectrum, *soft* enforceability mechanisms are stochastic in nature and rely on machine learning models or LLMs to enforce a policy. Given this stochasticity, there is no guarantee of success.
3. **Stack Enforcement** This dimension refers to the place where the policy is enforced within the GenAI application. Common places include: the LLM itself (e.g., activation steering) or specific places in the application such as MCP server. This dimension is also critical for *defense in depth* which at its core requires instantiating multiple mitigation mechanisms.

3.1 Interactions between policy definition and enforceability

We now analyze the interactions between the *policy definition* and the *enforceability* dimensions. We use a graphical representation with two axis as depicted in Fig. 4. In practice, there may be multiple ways in which a policy definition may be enforced. This flexibility and the newer capabilities of LLMs sometimes lead to undesirable selections that compromise the security, safety and compliance of the system.

Understanding the quadrant. We define a tuple $T = \langle \mathcal{P}, \mathcal{E} \rangle$ where its first component $\mathcal{P}$ contains the policy definition, and the second $\mathcal{E}$ the enforcement mechanism used. Fig. 4 locates example tuples across different policy domains. The objective is to locate tuples of policy definition and enforcement mechanisms in *general* regions rather than generating strict orders among tuples.

As a first example consider *Content Moderation* (Fig. 4a) shows two different policy definitions one very concrete: “Forbidden list words” which can

be enforced deterministically (hard enforcement), vs. a more fuzzy definition “Prevent hateful speech” which can be enforced using a machine learning model guardrail trained for that purpose resulting in stochastic enforcement e.g., [78, 44, 57]. Both these policy enforcement mechanisms are traditional and adequate. In some cases using both of them simultaneously is suitable to capture policy violations.

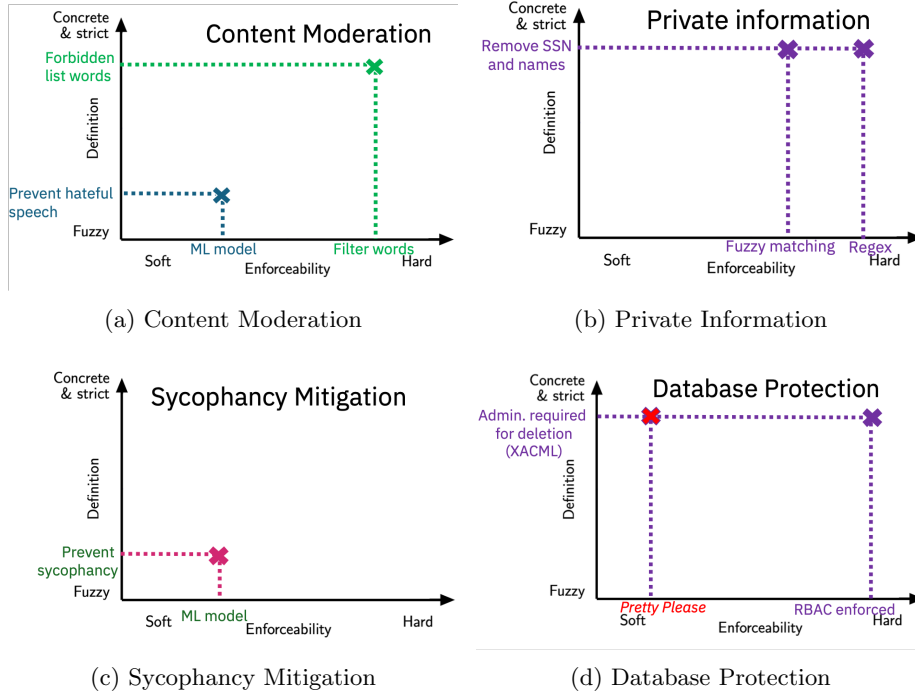


Figure 4: Four use cases mapped by definition clarity (fuzzy to concrete) and enforceability (soft to hard).

In *Private Information* (Fig. 4b) “Remove SSN and names” is a concrete definition that can be enforced with hard controls like regex matching. This enforcement can be combined with a more stochastic policy enforcement such as fuzzy matching [20] to filter private data.

Another policy “Prevent sycophancy” (Fig. 4c) has inherently fuzzy definition and requires soft enforcement. The concept of sycophancy in itself is fuzzy [23] with the research community still studying the phenomenon. Current enforcements mechanisms to mitigate sycophancy include activation steering [23, 80], a technique that changes the LLMs behavior stochastically at runtime. There is no enforcement mechanism that is deterministic and offers provable results; yet not mitigating this risk can lead to catastrophic life-death situations [27]. In this case, the enforcement is soft, but given the type of policy definition, it is the best that can be done.

Let’s examine policies related to database protection (Fig. 4d). The cybersecurity community enforces policies that restrict access to resources such as dataset by specifying the policy using formal language and using enforcement mechanisms that are carefully placed in the application stack to have provable guarantees of enforcement (Section 4 provides more details about these solutions and their properties). A new set of enforcement mechanisms have taken GenAI applications by storm. We call them *Pretty Please policy enforcement* and have very different properties compared to traditional cybersecurity enforcement mechanisms.

The rise of the *Pretty Please* Policy Enforcement. With the increase of instruction following capabilities of LLMs, policy definitions have changed dramatically enabling users to specify policies in natural language – something that was not possible before. What’s more interesting is the fact that any policy written in natural language can be enforced (or at least give the impression of being enforced) asking the LLM to adhere to the desired policy. We call this *Pretty Please policy enforcement*. This type of enforcement is typically done through system prompt (where main directives of operation are typically given to the LLM) and *in-context learning* [16] (where multiple examples of *good* and *bad* behavior are provided in a prompt). Hence, there is no enforcement guarantee.

A real example of a *Pretty Please* policy can be seen in Fig. 5 where the prompt to define a router includes information about the task at hand and the policy by which such router should be governed “*Strictly adhere to the following rules: never shared personal data, always verify claims, and use markdown policy*” [18]. In this setting, the enforcement is done by the router which is implemented as an LLM. This is a *Pretty Please* with *no* enforcement guarantee.

The deletion incident of the production database discussed in the introduction [64] (Fig. 1) was caused by the use of a soft *Pretty Please policy* instead of a hard, well-establish policy enforcement mechanism. In this case, good security practices require having access control policies written in languages such as XACML or OPA [36] and enforced by carefully implemented engines injected in enforcement points that cannot be circumvented to achieve as much as possible deterministic enforcement. Fig. 4d shows the difference between these enforcement in the analysis quadrant. The use of *Pretty Please* policy enforcement is not isolated, for example, it has been used in [104, 106, 105, 67, 50].

What is both deeply interesting and troubling about the *Pretty Please* enforcement is that *any* type of policy definition can be *attempted* to be enforced that way: all that’s needed is a prompt. Easiness of specification and deployment seems to be the reason for adoption despite lack of enforceability. Let’s examine in more detail the risks associated with *Pretty Please* policy enforcement.

The perils of the *Pretty Please* Policy Enforcement. This enforcement mechanism is problematic because it relies solely on the LLM, a highly stochastic system, to enforce the policy. It is equivalent to ask *Pretty Please don’t delete my database* - it may or may not work.

In addition, enforcement through LLMs is subject to a variety of undesirable

Example: Router/Constitution Prompt

“You are a master productivity router. Your job is to analyze the user’s request, delegate it to the appropriate sub-agent (Research, Writing, or Coding), and synthesize their final response.”

1. **Governance:** Strictly adhere to the following rules: never share personal data, always verify claims, and use mark-down formatting.
2. **Conditional Logic:** If the user requests code, route to the Coding Agent. If they request long-form text, route to the Writing Agent.
3. **Output:** Provide a brief summary of which agent you chose and why, followed by the final deliverable.”

Figure 5: Example prompt to guide a router agent. Governance constraints are specified as part of the prompt. While providing these instructions may *help* the LLM generate suitable plans, they should be taken as a *Pretty Please* request. There is no guarantee they will be fulfilled.

behaviors:

- *Non-adversarial settings:* even under normal circumstances LLMs have been shown to 1) exhibit unpredictable stochastic errors [60] where, for example, a benign error, like a missing file or a 404 page, may trigger the agent to follow undesirable and sometimes dangerous actions such as conducting unauthorized reconnaissance or subverting access control, 2) not follow system prompts adequately [72], 3) suffer from *reward hacking* [3] where the model attempts to complete a task at all costs to get its final reward (task marked as successfully completed) even if the actions are unethical or otherwise undesirable and also, 4) collude with other agents in unpredictable ways [73].
- *Adversarial vulnerabilities:* LLMs are subject to jailbreaks, direct and indirect prompt injections [77, 70] that make them a target to adversaries motivated to circumvent any *Pretty Please* policy as demonstrated by FragFuse [83].

For all these reasons, relying on *Pretty Please* policy *enforcement* is not recommended when there is a route to enforce through hard mechanisms. To be clear, there is nothing wrong in providing a *Pretty Please description* to *guide* the LLM in the selection of suitable agentic plans; what we are highlighting is that a description of desired behavior should not be confused with *adequate enforcement*.

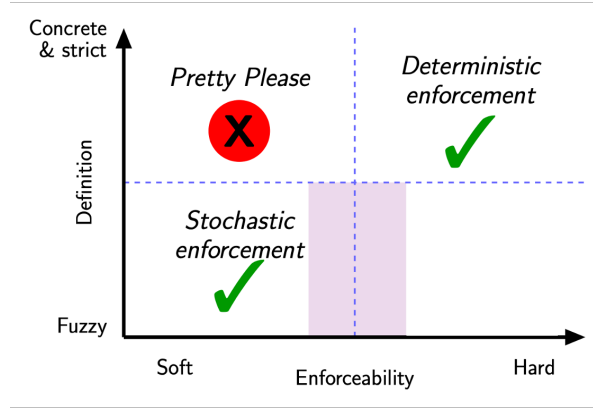


Figure 6: Recommendation: Not all policies are the same. They need different enforcement mechanisms depending on the policy specification.

Takeaway 1 *Don't rely on Pretty Please prompts to enforce policies, they are meant to guide the LLM behavior (without guarantee), but are not suitable to ensure the policy is enforced.*

In Fig. 6, we split the space of interaction between policy definition and policy enforceability in five regions according to their suitability:

1. *Deterministic enforcement region*: This is a desirable region. In this region lie policies where a concrete definition is paired with a hard deterministic enforcement.
2. *Stochastic enforcement region*: This is a desirable region for fuzzy policies that can only be enforced with stochastic methods like the sycophancy example.
3. *The Pretty Please region*: This is an undesirable region where despite the existence of a concrete policy definition and deterministic enforcement mechanisms, a *Pretty Please* enforcement is selected. Deployments should aim to select enforcement mechanisms that are hard.
4. *Semi-stochastic region (purple)*: In this region, we see a rise of solutions that try to reduce stochasticity of purely using generative models by dividing complex instructions into atomically in a way that the LLM work is closely monitored, verified and re-done if necessary. Example approaches include Mellea where policies can be enforced through atomic functions [55].

Takeaway 2 *Prefer hard policy mechanisms when the policy definition supports them, following Fig. 6 recommendations.*

3.2 The Stack Enforcement and Defense in Depth

The third dimension we analyze as part of the proposed methodology is the *stack enforcement*.

3.2.1 Defense in Depth

An additional important distinction between enforcement mechanisms is where in the stack the enforcement takes place. Defense in depth is an important factor in cybersecurity and governance with the Swiss cheese model [99] (Fig. 7a) exemplifying how to ensure multiple layers of defenses are orchestrated to provide defense in depth.

During our tour of the wild, we uncovered a common pitfall that we explain through an analogy: some practitioners are confusing a *donut* (term coined in this paper) with the Swiss cheese model (Fig. 7).

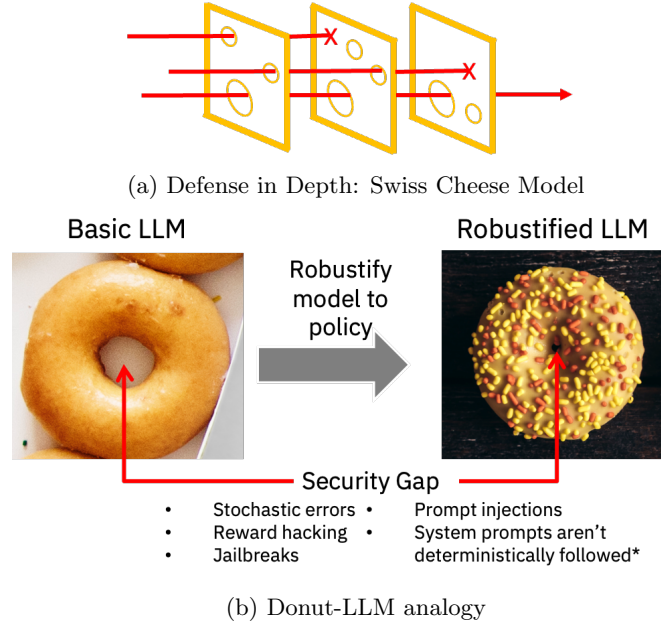


Figure 7: Analogy: If an LLM was a *donut*, we could see its security gap (Fig. 7b). The *Pretty Please* prompts do not close that gap. Methods to robustify the model such as alignment, fine tuning, and unlearning may help reduce the gap – resulting in a sprinkle donut. To this date, no method guarantees the gap will be fully closed. A *donut* is a single layer of defense in the Swiss Cheese model.

At the core of any GenAI application there is an LLM. If the LLM was a donut, we could see its security hole consisting of stochastic errors, jailbreaks, prompt injections and lack of reliable prompt following capabilities [60, 72].

Pretty Please policies do not close this security gap, thus using them does not reduce risk in a reliable way.

To close the security gaps of LLMs, techniques such as alignment, unlearning and fine tuning have been developed. These techniques manipulate the LLMs to increase its reliability for different tasks. When they are used to improve policy compliance, they can indeed reduce the security gap of the model. In particular, when these model adaptations are tailored by policies or policy-driven red teaming. Going back to the analogy, the adapted model is a sprinkle donut with a smaller security gap. However, it is important to note that the LLM (donut) will always have some stochastic component and a security gap that, to this date, cannot be fully closed. The *sprinkled donut* is more robust than the *generic* donut: always prefer a sprinkle donut. However, a donut with or without sprinkles remains a single layer of defense. Whether there is a *Pretty Please* policy in place or not, this fact does not change.

True defense in depth requires more than using *Pretty Please* prompts, or robustifying an LLM (donut with sprinkles). It requires having multiple components orchestrated across the application. Avoid reusing the same model to guard itself to mitigate its resulting actions suffering from reward hacking, jailbreaks or injection prompts.

Takeaway 3 *True defense in depth requires multiple layers of protection. A single model, even if it is robustified, or if it has been given Pretty Please prompts, should be considered as a single layer of protection. It needs to be deployed with further safeguards.*

3.2.2 Using Policy Enforcement Points

The number of places where policy needs to be enforced in GenAI application is substantial (Table 2). The design principles from traditional cybersecurity are still valid in this GenAI era (see Section 4.1 for a detail review). In particular, separating policy definition, policy enforcement points through *hooks* that can integrate diverse enforcement mechanisms are some of the relevant design principles. A *hook* (as defined by Linux Security Modules [102]) should be placed in a spot in the application where policy enforcement is required. As shown in Fig. 3 and Table 2, there are multiple places in the stack where policy enforcement is needed. Ensuring hooks are placed in the right spots and tied to the right enforcement mechanism is important. Adding application hooks and linking them to hard enforcement mechanisms to reliably and deterministically verify certain actions, such as authentication and verification of access tokens is a must, can substantially improve the security of the system. For this purpose, architecting the right abstractions in the application is important, for example, using MCP [4] to help determine when an agent makes certain tool calls and then enforcing policies for example using MCP Context Forge [53]. Recent work [28, 56], shows how hooks have been inserted to enforce access control, identity management policies and various other policies. More details about these design principles and some systems implementing them can be found in Section 4.

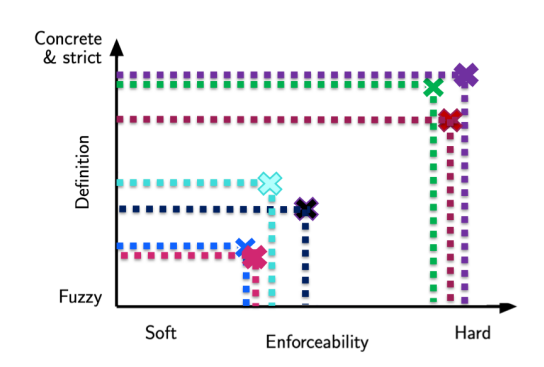


Figure 8: GenAI applications may need to comply with a variety of policies located in different regions of the quadrant imposing challenges to compliance

Takeaway 4 *Use well-defined policy enforcement points and maintain a clear policy definition.*

3.3 Enforcing Multiple Policies

GenAI application may require the enforcement of a variety of policies (Fig. 2) which need to be enforced in different places in the stack: model, tools, prompts and memory. Additional complexity arises from the fact that the enforcement mechanisms are quite diverse as shown in Table 2 and Fig. 8. We identify the following challenges:

Lack of a single control plane Ideally all policies could be visible from a single place. Currently, diverse mechanisms exist to enforce specific policies, e.g. OPA/REGO, Nemo Guardrails, among others. But they all limit themselves to limited types of policy. Using hooks for *any* enforcement is a good design principle to achieve this objective.

Log and agree on error definition “common errors” GenAI applications are bound to fail from time to time. With the increase of multi-agent applications, identifying where issues occur is important for compliance and recovery. Logging interactions is a must, and understanding what to log and communicate across agents is also very important. For example, in http, the error 404 means “Not Found error” which means the specific page or file requested does not exist. A recent approach [13], proposes defining policy definition that includes exception codes that should be triggered when failures occur. Implementing such type of policy enforcement and exception raising would improve compliance.

Takeaway 5 *Having a central control panel, capable of logging well specified errors, with ideally universal error codes can facilitate compliance.*

Conflict resolution When there are more than one policy, there may be conflicts [89, 62, 30, 51]. For example, one policy may require restricting an

agent from sending emails, while another one may require sending a message to an emergency contact when there is a self-harm emergency. Ensuring policy resolution is congruent with real objectives remains an open issues. The great majority of solutions, e.g., [84], rely on content similarity of user request to define the right policy to apply.

Takeaway 6 *In practice, multiple policies need to be enforced by a single GenAI application. The policies have fuzzy and concrete definitions and require both soft and hard enforcement mechanisms. They need to co-exist and be enforced together to prevent undesirable side effects due to conflicting objectives and obligations.*

4 Related work

Enforcing policies in GenAI applications and model is a popular topic. In this section, we present in more detail representative approaches clustering them based on the field they are proposed starting with cybersecurity.

4.1 Traditional Cybersecurity Policy Enforcement

Cybersecurity has studied extensively policy enforcement for traditional (non-GenAI) applications. Most of this work focuses on enforcing access control policies such as role-based access control (RBAC) [35], attribute-based policies (ABAC) [49], flow related access control such as BIBA’s [15] and Bell-Lapadula [14]. A wide range of application domains such as healthcare, information systems also require enforcing *obligations* [58, 81, 92, 66, 10], which dictate what actions need to be applied before and/or after the evaluation of a policy within a specify amount of time. Obligations are combined with a variety of access control models.

The security community has also focus widely on enforceability and composability of policies. Access control models are frequently modeled as state machines and policies are described using grammars and policy languages to ensure policy enforceability. Based on these clear defined abstractions, it is possible to analyze composability of policies. Composability of multiple policies may lead to conflicts [89, 62, 30, 51]. Approaches in this area aim to determine conflicts of policies written in grammars that can be reasoned upon. Conflicts are resolved using rules that specify what policy should prevail; in healthcare, conflict resolution may also include *break-the-glass* policies where a system may violate *normal* policy under very specific circumstances [17]. For example, denying an access to a healthcare chart may result in death if the patient is in ER. A break-the-glass policy states that a doctor in ER taking care of the patient may access his chart even if she is not the primary physician. Additional work has pointed out the necessity of ensuring enforceability of obligations and finding potential conflicts that may prevent an agent or user from completing one such obligation [10, 24, 12], for a user process may not be able to complete an obligation if it

lacks of privileges to carry out the require action. Well-defined grammars are in sharp contrast with soft policies (written in natural language and LLM-based detectors), we have found in the wild, e.g., [104, 106, 105, 67, 50].

Good policy enforcement designs have also been a core component of cybersecurity. Among the aspects that have been widely discuss are the appropriate design of applications that need to ensure enforceability of policies with minimum modification of application code to ensure easy maintenance. In particular, designing applications ensuring *policy enforcement point* (PEP), *policy decision point* (PDP) and *policy information point* (PIP) provides flexibility and enforceability in a modular way. Figure 9 shows this architecture. Policy specifications are stored in the PIP ensuring they can be updated without modifying the application or other components. The PEP serves as an execution monitor [88] ensuring interactions are intercepted and calling the PDP, which decides if there are any policy violations by querying the PIP for relevant policies. In this way, it is possible to ensure policies are maintained separately to the application’s logic. They can also be one or more PIPs to ensure reliability. Traditionally, the PDP returns to the PEP a *grant/deny* that it is then enforced by the PEP by blocking access or granting access to the particular resource. In some special cases when *obligations* exist, the PDP returns the obligation(s) that needs to be fulfilled, and the PEP is in charge of completing the obligation. In cases where there are conflicts in the PIP, the PDP finds them and decides what to do with such conflict. Addressing conflicts in general requires reasoning among policies written in well established grammars. In contrast, a lot of the frameworks that inspect natural language violations in GenAI address conflicts through embedding similarity, e.g., [84].

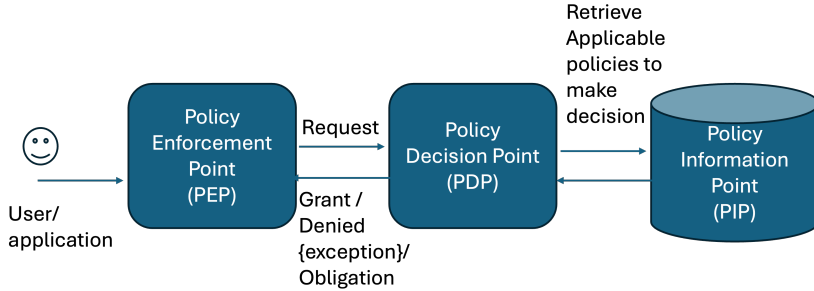


Figure 9: Policy enforcement for traditional access control applications. The design enables modularization and improves enforceability especially for distributed applications. Having an independent PIP facilitates updating policies dynamically. This design can also be used for GenAI applications.

Linux Security Module (LSM) [102] is a framework that supports a variety of security access control models in Linux Kernel through *hooks* and follows similar design principles separating PIP, PDP and PEP. In LSM, a hook is a function with a well defined signature placed at critical security-relevant points

in code of the kernel –effectively making it a PEP. A *module* can be *plugged* into the *hooks* so that it is automatically called at these key points, and the result is used for enforcement, such as blocking the execution of the process. This design ensures modules can change without requiring modifications to the kernel itself. This design ensures the GenAI application does not need to be modified. Systems embracing hook architecture include [56]. An example design with this zero-trust in mind was presented in [28].

The GenAI area has brought with it a very different reality, where policies are broader and generally written in natural language. This is completely opposite to the very rigid and well-defined grammars used for traditional access control. We now overview additional types of policies and their enforcement.

4.2 Policies for System, Business Compliance and Logic

Multiple approaches in this bucket propose using natural language policies and transforming them into intermediate representations [107, 38, 1, 63]. In [107], a method that transforms policy documents into verifiable code associated with tool usage is provided. At runtime, these rules are verified to check compliance before the agent performs an action. This work limits itself to tool invocation verification. A similar work in [38] uses a LLM to transform into Prolog text-based policies written in natural language that dictate when a health insurance claim is valid or not. At runtime, the claim is fed to the LLM and the policies are evaluated in Prolog. A similar approach for law contracts was presented [63]. Another approach [1] proposes aligning the model to answer questions according to multiple policies. This method mainly deals with question-answer type of interactions. An example approach that deals with system related policies is OSCAL (Open Security Controls Assessment Language) created by NIST [37]. It aims to automate cybersecurity compliance by providing standardized, machine readable formats. None of these methods have been designed to comply with the multi-stakeholder policies.

Multiple approaches evaluate policy adherence by appending it directly to the prompt before querying the LLM [105, 67, 50] falling into the *Pretty Please* enforcement. Li et al. [67] propose a SOPBench, a benchmark to measure compliance of standard operating procedures (SOPs), e.g., “To schedule a driving test, please verify that the user is at least 16 years AND has passed the knowledge test.” SOPs described in natural language are transform into source code (oracle code), then LLMs are queried to evaluate if agents’ tool-calling trajectories follow the oracle code trajectories. The evaluation includes the SOP instruction as part of the prompt received by the LLM. Yao et al. [105], propose τ -bench a popular benchmark to measure policy compliance for airline use cases. The evaluations are performed by adding the domain policy as system prompt and user’s instructions as user prompt, respectively. A more elaborated benchmark *CRMarena* measures Customer Relationship Management (CRM) that mimic Sales force CRM [50]. Evaluation is performed by feeding a long prompt containing all the description of requirements and policy to the LLM or agent. Some of these works use *policy* to refer to *application logic rules* or

requirements. As discussed before, relying in these *Pretty Please* enforcement may lead to undesirable behavior.

4.3 Enforcing Policy by Adapting Models or Their Behavior

At their core, GenAI applications rely on LLM models to generate content and for that reason a variety of techniques have been proposed to modify models weights according to policy. These techniques include model alignment [25, 90, 98, 32, 9] and unlearning [69, 95, 68, 94]. On one hand, model alignment consists on training the model to *align* it with a policy [13, 47], which is also referred to as a model specification [40] or constitution [9]. A variety of optimization methods exist for this purpose including RLHF [25], multi-human-value alignment palette (MAP) [98], GRPO [90], SFT [101, 32], DPO[82], among others. Unlearning on the other hand, has been proposed to carefully remove unwanted behavior or data from the model by carefully changing the model once a problem has been detected. A variety of approaches have also been designed to train LoRA [48] and aLoRA adapters [43], where the latter are activated at runtime via a special token.

An additional trend is to modify model behavior at runtime by steering the model’s activations [23]. Recently [87] proposes marrying the policy rules with activation monitoring to ensure policy failures are corrected on the fly at runtime. These methods are promising and further study on their potential side effects is needed.

Prior work [13, 57] proposed YAML-based policy specifications to define how the model should answer. In [13], besides specifying what the model can and cannot output, the policy also defines the *exception* that should be triggered when policy gets violated facilitating compliance verification. This type of setup can help understand failures across multiple agents and policies.

4.4 Stochastic Methods and Efficacy Evaluation

GuardAgent [104] aims to enforce policy in agents by generating plans that consider a policy. It relies solely on prompt-based interventions (even for traditional access control policies). ShieldAgent [22] uses a probabilistic policy reasoning enforcement module where policy constraints are compiled from documents to generate action-based rule circuits. During setup, each circuit associates an agent action with relevant rules for verification. At runtime, ShieldAgent *i*). receives the plan generated by the LLM it guards, *ii*) formats it and retrieves similar workflows (from long term memory where what has been labeled as safe interactions have been previously stored)¹, *iii*) uses them as in-context learning samples with the objective of generating a safe plan and *iv*) verifies each rule and makes a final probabilistic inference. AGrail [71] proposes a risk mitigation

¹This can be problematic if access has been revoked, for example, if the employee is no longer at the company.

framework that uses multiple LLMs to detect generic *universal* and manually specified risks. Embedding vectors are used to verify what risks are relevant for a given request. Conseca [91] was proposed to secure general purpose agents, where anticipating all relevant contexts, tasks and proving policies for them may not be feasible. To overcome the hurdle of specifying policies for each potential context manually, Conseca uses an LLM to generate on the fly policies for fine-grained contexts. Their implementation uses hooks and a deterministic policy enforcer; the policy itself, however, is generated based on in-context learning examples and non-deterministic. AuthGraph uses an authorization graph and a provenance graph to prevent malicious accesses. The construct increases contextual information to make it more difficult to subvert the agent, but still relies on an LLM is used for attribution capabilities.

Evaluation. FragFuse presents a method to bypass LLM-based access control mechanisms [83] by manipulating the instruction that is sent to the LLM-based access control module. The method modifies long term memory by splitting the undesirable instruction into chunks that are mix with other benign content. Four agents were evaluated using LLM-based access control that consisted of a *Pretty Please policy* injected in the prompts which were unsurprisingly broken. FragFuse also tested GuardAgent, AGrail and ShieldAgent as enforcement mechanisms. All these methods were broken by the attack showcasing the need to have hook-based deterministic access control approaches that are not based on prompt ingestion.

In [72], a benchmark to measure how effective are models at enforcing conflicting instructions specified at different hierarchies (system vs. user), demonstrating that current models do not respect these hierarchies, and using *Pretty Please* enforcement (prompts) is not enough to reliably enforce policies.

Agent Meltdowns under non-adversarial settings are studied in [60], showcasing the need to monitor and include defenses outside the LLM. The paper studies the behavior of agents when they encounter simple benign errors such as missing an expected file, and reports 64.7% of agent rollouts that encounter simulated errors, resulted in dangerous actions such as conducting unauthorized reconnaissance or subverting access control. Interestingly, the study finds that in over half of the dangerous failures (meltdowns), the unsafe behavior was never reported to the user. These findings showcase the evident need of having defense in depth.

The Coalition for Secure AI also published a set of recommendations to address agent containment challenges [29] (agents escaping their sandboxes), where using hooks to monitor and stop unexpected and malicious behavior was recommended urging treating agents as an insider threat. Overall, it requires having a more robust policy enforcement.

4.5 Guardrails and Enforcement Frameworks

Guardrails models have been developed to prevent a variety of harms [78, 57, 78, 41, 52] by intercepting input-output responses of LLMs. Most of them inspect for pre-defined risks. Recently, some of them have added ways to verify for par-

ticular risks using techniques such as bring your own risk that can be used for policy verification². Other approaches focus on multi-turn interactions. A recent work monitors multi-turn conversation for [45] that monitors independently intent, context plausibility and manipulation and consistency. NeMo Guardrails [84] is a toolkit to define and steer conversations based on pre-defined policies. Valid conversation flows are specified in the formal language *Colang*. At runtime NeMo acts as a proxy between the user and the LLM, selecting guardrails and modifying conversation flows according to Colang rules. Enforcement of policies relies on selecting the next steps to guide the conversation. When a user-model interaction is taking place, an *embedding vector* is created and used to select the most relevant policy. As such, policy conflict resolution is based on a stochastic nearest neighbor algorithm. The final enforcement is also stochastic and uses prompting with in-context learning. This external verification adds defense in depth.

4.6 Harnesses and Systems

Multiple frameworks have been proposed in this space. Mellea [55] aims to “*build predictable AI without guesswork*” by creating *generative programs* written in python which verify compliance with requirements during the workflow of a GenAI application. Mellea uses *hooks* [56] to enforce policies linked to tool calling. A compiler to certify skills with Mellea was also provided [31]. LangChain [65] is a platform to build AI agents, where users can implement custom or predefined guardrails. Rails regulate pre-and-post tool calling interactions. Vertex AI Engine [39], a product offering from Google enable the deployment of agents. The framework allows users to specify python functions, authenticate, access control and enable content filters. There is no default way to specify and manage conflicts caused by multiple policies. CodeGuard from CISCO [26] provides a list of rules to help prevent the generation of vulnerable software. These rules can be used before, during and after code generation to prevent insecure defaults, hard-coded secrets, use of outdated cryptographic algorithms. Open Claw [75] is an open-source autonomous artificial intelligence agent Agents specification is defined in a file SOUL.md that contains its name, desired tone, hard limits (never share private information) and core behaviors [19]. However, these are essentially *Pretty Please* prompts. Enforcement mechanisms in these two clusters are usually found as packages, plugins or modules for users to integrate into their application [26].

4.7 Policy Composition Conflict Resolution

Policy conflict resolution has been studied extensively for traditional access control systems (see Section 4.1). However, enforcing policies in GenAI applications requires addressing conflicts of a variety of policies wider than access control (see Table 2). Work in this area mainly focuses on multi-agent policy agreement,

²To see an example of such usage: https://github.com/ibm-granite/granite.trust.policy-tools/blob/main/notebooks/guardian_enforcement.ipynb

where conflicts in policies among multiple agents are resolved using pre-defined rules, voting to arrive into a consensus or using an LLM to resolve the discrepancy among policies [86]. Other approaches use *Rule-based precedence systems* like OPA/Rego use explicit deny-overrides or permit-overrides semantics borrowed from traditional access control. *Semantic similarity approaches* e.g., [84] select the most relevant policy based on embedding distance to the user request, but this introduces stochasticity into what should be a deterministic decision. None of these approaches provide formal guarantees when policies span multiple enforcement types (e.g., a soft content policy conflicting with a hard access control policy).

5 Conclusion

The dramatic growth in capabilities of LLMs has led to new applications and the need to ensure compliance with policies. Our survey of what practitioners refer to as *policy* reflects the fact that there are a big set of diverse policies that vary in their objectives and where they need to be enforced. We proposed dissecting policy techniques to identify good and bad practices by taking into consideration three different dimensions of policies and how they relate to each other. Fig. 6 summarizes our recommendations in terms of policy enforcement selection. In addition, we draw the following lessons:

1. *Just because you can, doesn't mean you should* Our methodological framework highlights that the capabilities of LLMs have led to a plethora of *fuzzy* policy definitions that could not be enforced prior to the LLM era. At the same time, we see “unreliable” enforcement mechanisms (LLM-based) being used to enforce strict policies that can be enforced with hard mechanisms. These deployment choices can lead to a false sense of security: if there is a well-defined policy, enforcement mechanisms that are non-stochastic should be used.
2. *Defense in Depth: A Sprinkle Donut is not the same as a Swiss Cheese model* Our analysis also shows an increase of prompt-based solutions that tend to encompass multiple desirable conditions to be enforced centrally by a single model. We argue that this *Pretty Please Policy* enforcement mechanisms lead to a Sprinkle Donut not a Swiss Cheese Model: the same model cannot guard itself. True defense in depth requires having multiple mechanisms besides the LLM. This is particularly true given that LLMs are well known for their vulnerability to stochastic failures, jailbreaks, prompt injection attacks and reward hacking.
3. *Stack Enforcement* Compliance requires logging information to verify the desired properties of a system. We argue that lessons learned by traditional cybersecurity are *mostly* applicable to GenAI applications. This include the use of Policy Enforcement, Decision and Information Points while designing GenAI applications. Other solutions such as those inspired

by SELinux hooks can help shape the field. In Section 4.1 we discuss some nuances that make it difficult to fully apply some of the concepts to GenAI applications. These remain open challenges for the community to address.

4. *Interoperability and Conflict Resolution* Our analysis surfaces two gaps the community must address. First, standardized failure semantics across GenAI applications: the equivalent of HTTP 404 for policy violations. Some initial solutions [13] propose a unified set of exception codes well understood across GenAI applications. Second, principled approaches to resolving conflicts when multiple policies apply simultaneously. Current approaches rely on vector similarity, which lacks the formal guarantees of traditional access control conflict resolution. Addressing conflicting policies across the diverse set of policies a single application is subject to remains an open challenge.

We hope that this paper leads to a constructive collective understanding of what different communities mean by policy and of the multiple efforts that aim to make GenAI safer, secure and compliant. We proposed an analytical framework that offers a way for practitioners to systematically identify potential failures and gaps, and truly develop a defense-in-depth solution.

Acknowledgments

I wrote this paper while preparing for my *USENIX Security 2026 Enigma* track presentation [11] as extended companion material of my talk. I want to thank Kendra Albert and David Freeman who listened to an earlier version of my presentation and provided feedback. Their input helped shape the presentation and analogy of the LLM as a *donut* with a hole; originally it was another type of pastry. My points of view have been shaped by extensive reading, examining source code and talking to multiple practitioners. I would like to thank them all.

Author Biography

Nathalie Baracaldo is a Senior Research Scientist and Master Inventor at IBM Research in San Jose, California, where her work focuses on building trustworthy AI systems. She has extensive experience delivering impactful machine learning solutions that are highly accurate, withstand adversarial attacks, and protect data privacy. Her current research focuses on safeguarding generative AI through unlearning and alignment techniques. She served as the principal investigator for the DARPA GARD program, leading efforts to extend and maintain the Adversarial Robustness Toolbox (ART) for red teaming evaluations. She also led IBM’s federated learning initiative and co-edited two books: “Federated Learning: A Comprehensive Overview of Methods and Applications” (Springer, 2022) and “Machine Unlearning for Governance of Foundation Models” (2026). Her research has been published in top AI and security conferences, earning multiple best paper awards and thousands of citations. She received the IBM Master Inventor distinction in 2020 and the Corporate Technical Recognition in 2021. She holds a Ph.D. from the University of Pittsburgh.

References

- [1] Swapnaja Achintalwar, Ioana Baldini, Djallel Bouneffouf, Joan Byamugisha, Maria Chang, Pierre Dognin, Eitan Farchi, Ndivhuwo Makondo, Aleksandra Mojsilović, Manish Nagireddy, et al. Alignment studio: Aligning large language models to particular contextual regulations. *IEEE Internet Computing*, 28(5):28–36, 2024.
- [2] Thorn AI. Thorn: Defend children from sexual abuse.
- [3] Dario Amodei, Chris Olah, Jacob Steinhardt, Paul Christiano, John Schulman, and Dan Mané. Concrete problems in ai safety. *arXiv preprint arXiv:1606.06565*, 2016.
- [4] Anthropic. Mcp. <https://www.anthropic.com/news/model-context-protocol>, 2024.
- [5] Anthropic. Agents for financial services. <https://www.anthropic.com/news/finance-agents>, 2026.

- [6] Anthropic. Claude’s new constitution, 2026.
- [7] Anthropic. Data retention practices for covered models. <https://support.claude.com/en/articles/15425996-data-retention-practices-for-covered-models>, 2026.
- [8] Sadia Asif, Mohammad Mohammadi Amiri, Momin Abbas, Prasanna Sattigeri, and Karthikeyan Natesan Ramamurthy. Lcgaurd: Latent communication guard for safe kv sharing in multi-agent systems. *arXiv preprint arXiv:2605.22786*, 2026.
- [9] Yuntao Bai, Saurav Kadavath, Sandipan Kundu, Amanda Askell, Jackson Kernion, Andy Jones, Anna Chen, Anna Goldie, Azalia Mirhoseini, Cameron McKinnon, et al. Constitutional ai: Harmlessness from ai feedback. *arXiv preprint arXiv:2212.08073*, 2022.
- [10] Nathalie Baracaldo. *Tackling insider threats using risk-and-trust aware access control approaches*. PhD thesis, University of Pittsburgh, 2016.
- [11] Nathalie Baracaldo. From alignment to access control: A unified view of {GenAI} policy enforcement. *Usenix Security - Enigma Track*, 2026.
- [12] Nathalie Baracaldo and James Joshi. Beyond accountability: using obligations to reduce risk exposure and deter insider attacks. In *Proceedings of the 18th ACM symposium on Access control models and technologies*, pages 213–224, 2013.
- [13] Nathalie Baracaldo, Nicolas Mello, Kush R. Varshney, Heiko Ludwig, Kate Soule, and David Cox. Granite.trust policy tools: Shareable, actionable policies for generative ai applications, 2026.
- [14] D Elliot Bell and Leonard J LaPadula. Secure computer systems: Mathematical foundations, 1973.
- [15] Kenneth J Biba. Integrity considerations for secure computer systems, 1977.
- [16] Tom Brown, Benjamin Mann, Nick Ryder, Melanie Subbiah, Jared D Kaplan, Prafulla Dhariwal, Arvind Neelakantan, Pranav Shyam, Girish Sastry, Amanda Askell, et al. Language models are few-shot learners. *Advances in neural information processing systems*, 33:1877–1901, 2020.
- [17] Achim D Brucker and Helmut Petritsch. Extending access control models with break-glass. In *Proceedings of the 14th ACM symposium on Access control models and technologies*, pages 197–206, 2009.
- [18] AI Overview by google. Screenshot of constitution prompt suggested to create an ai agent router., 2026.

- [19] Roberto Capodiecici. Ai agents 003 - openclaw workspace files explained: Soul.md, agents.md, heartbeat.md and more. <https://capodiecici.medium.com/ai-agents-003-openclaw-workspace-files-explained-soul-md-agents-md-heartbeat-md-and-more-5bdfbee4827a>, 2026.
- [20] Michel Cayrol, Henri Farreny, and Henri Prade. Fuzzy pattern matching. *Kybernetes*, 11(2):103–116, 1982.
- [21] Character.ai. Character.ai — ai chat, reimagined—your words. your world. <https://character.ai>.
- [22] Zhaorun Chen, Mintong Kang, and Bo Li. Shieldagent: Shielding agents via verifiable safety policy reasoning. *arXiv preprint arXiv:2503.22738*, 2025.
- [23] Myra Cheng, Sunny Yu, Cinoo Lee, Pranav Khadpe, Lujain Ibrahim, and Dan Jurafsky. Elephant: Measuring and understanding social sycophancy in llms. *arXiv preprint arXiv:2505.13995*, 2025.
- [24] Omar Chowdhury, Murillo Pontual, William H Winsborough, Ting Yu, Keith Irwin, and Jianwei Niu. Ensuring authorization privileges for cascading user obligations. In *Proceedings of the 17th ACM symposium on Access Control Models and Technologies*, pages 33–44, 2012.
- [25] Paul F Christiano, Jan Leike, Tom Brown, Miljan Martic, Shane Legg, and Dario Amodei. Deep reinforcement learning from human preferences. *Advances in neural information processing systems*, 30, 2017.
- [26] CISCO. Project codeguard: Security rules for ai coding agents, 2025.
- [27] CNN. Character.ai and google agree to settle lawsuits over teen mental health harms and suicides. <https://www.cnn.com/2026/01/07/business/character-ai-google-settle-teen-suicide-lawsuit>, 2026.
- [28] Coalition for Secure AI. Zero trust for ai systems: Why authorization can't live inside the model. <https://www.coalitionforsecureai.org/zero-trust-for-ai-systems-why-authorization-cant-live-inside-the-model/>, 2026.
- [29] COS. Treat your agent like an insider threat: Why ai sandboxing can't wait, 2026.
- [30] Frédéric Cuppens, Nora Cuppens-Boulahia, and Meriam Ben Ghorbel. High level conflict management strategies in advanced access control models. *Electronic Notes in Theoretical Computer Science*, 186:3–26, 2007.
- [31] Elizabeth M. Daly, Dhaval Salwala, Inge Vejsbjerg, Seshu Tirupathi, Rebecca Nordenlöw, Jessica He, Kush Varshney, and McAfoose Jordan. Mellea skills compiler: Compiling and certifying agent skills with mellea, 2026.

- [32] Fei Ding and Baiqiao Wang. Improved supervised fine-tuning for large language models to mitigate catastrophic forgetting. *arXiv preprint arXiv:2506.09428*, 2025.
- [33] everyone.ai. Aia safety builder.
- [34] FelonyBench. Felonybench: The leading benchmark for ai in cybersecurity. <https://felonybench.org/>, 2026.
- [35] David F Ferraiolo, Ravi Sandhu, Serban Gavrila, D Richard Kuhn, and Ramaswamy Chandramouli. Proposed nist standard for role-based access control. *ACM Transactions on Information and System Security (TISSEC)*, 4(3):224–274, 2001.
- [36] Cloud Native Computing Foundation. Open policy agent. <https://www.openpolicyagent.org>.
- [37] Cloud Native Computing Foundation. Oscar compass. <https://github.com/oscal-compass>, 2026.
- [38] Oliver Goodenough. Why a logic programming approach works for automating insurance contracts. <https://law.stanford.edu/2023/03/10/why-a-logic-programming-approach-works-for-automating-insurance-contracts/>, 2023.
- [39] Google. Vertex ai agent builder. <https://cloud.google.com/products/gemini-enterprise-agent-platform>, 2025.
- [40] Google. Model alignment of gemma. https://colab.research.google.com/github/pair-code/model-alignment/blob/main/notebooks/Gemma_for_Model_Alignment.ipynb, 2026.
- [41] Google. Shieldgemma 2. <https://ai.google.dev/gemma/docs/shieldgemma>, 2026.
- [42] Google. Vertexai, 2026.
- [43] Kristjan Greenewald, Luis Lastras, Thomas Parnell, Vraj Shah, Lucian Popa, Giulio Zizzo, Chulaka Gunasekara, Ambrish Rawat, and David Cox. Activated lora: Fine-tuned llms for intrinsics. *arXiv preprint arXiv:2504.12397*, 2025.
- [44] GuardRails AI. Guardrails ai. <https://www.guardrailsai.com/>, 2026.
- [45] Michele Guida, Ruslan Shikhamzayev, Sindhuja Penchala, Stefano Iannucci, Jiacheng Li, Shahram Rahimi, and Noorbakhsh Amiri Golilarz. Cognitive firewall: A proactive, zero-trust, multi-gate framework for llm safety. *arXiv preprint arXiv:2607.01277*, 2026.

- [46] Feng He, Tianqing Zhu, Dayong Ye, Bo Liu, Wanlei Zhou, and Philip S Yu. The emerged security and privacy of llm agent: A survey with case studies. *ACM Computing Surveys*, 58(6):1–36, 2025.
- [47] Lukas Helff, Felix Friedrich, Manuel Brack, Patrick Schramowski, and Kristian Kersting. Llavaguard: Vlm-based safeguard for vision dataset curation and safety assessment. In *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition*, pages 8322–8326, 2024.
- [48] Edward J Hu, Yelong Shen, Phillip Wallis, Zeyuan Allen-Zhu, Yuanzhi Li, Shean Wang, Liang Wang, Weizhu Chen, et al. Lora: Low-rank adaptation of large language models. *Iclr*, 1(2):3, 2022.
- [49] Vincent C Hu, D Richard Kuhn, David F Ferraiolo, and Jeffrey Voas. Attribute-based access control. *Computer*, 48(2):85–88, 2015.
- [50] Kung-Hsiang Huang, Akshara Prabhakar, Sidharth Dhawan, Yixin Mao, Huan Wang, Silvio Savarese, Caiming Xiong, Philippe Laban, and Chien-Sheng Wu. Crmarena: Understanding the capacity of llm agents to perform professional crm tasks in realistic environments. In *Proceedings of the 2025 Conference of the Nations of the Americas Chapter of the Association for Computational Linguistics: Human Language Technologies (Volume 1: Long Papers)*, pages 3830–3850, 2025.
- [51] Nghi Huynh, Marc Frappier, Herman Pooda, Amel Mammar, and Régine Laleau. Sgac: A multi-layered access control model with conflict resolution strategy. *The Computer Journal*, 62(12):1707–1733, 2019.
- [52] IBM. Granite guardian hap 38m.
- [53] IBM. Contextforge. <https://github.com/IBM/mcp-context-forge>, 2026.
- [54] IBM. Contextforge: Mcp gateway. <https://github.com/IBM/mcp-context-forge>, 2026.
- [55] IBM. Mellea. <https://github.com/generative-computing/mellea/tree/main>, 2026.
- [56] IBM. Mellea: Plugins & hooks. <https://docs.mellea.ai/concepts/plugins>, 2026.
- [57] Hakan Inan, Kartikeya Upasani, Jianfeng Chi, Rashi Rungta, Krithika Iyer, Yuning Mao, Michael Tontchev, Qing Hu, Brian Fuller, Davide Testuggine, and Madian Khabsa. Llama guard: Llm-based input-output safeguard for human-ai conversations. *arXiv preprint arXiv:2312.06674v1*, 2023.

- [58] Keith Irwin, Ting Yu, and William H Winsborough. On the modeling and analysis of obligations. In *Proceedings of the 13th ACM conference on Computer and communications security*, pages 134–143, 2006.
- [59] Julie Jargon. The three chatbot behaviors that can drive humans to delusional thinking. *The Wall Street Journal*, 2026.
- [60] Rishi Jha, Harold Triedman, Arkaprabha Bhattacharya, and Vitaly Shmatikov. Agent meltdowns: The road to hell is paved with helpful agents. *arXiv preprint arXiv:2605.19149*, 2026.
- [61] Saurabh Jha, Rohan Arora, Yuji Watanabe, et al. Itbench: Evaluating ai agents across diverse real-world it automation tasks, 2025.
- [62] James BD Joshi. Access-control language for multidomain environments. *IEEE Internet Computing*, 8(6):40–50, 2004.
- [63] Manuj Kant, Sareh Nabi, Manav Kant, Roland Scharrer, Megan Ma, and Marzieh Nabi. Towards robust legal reasoning: Harnessing logical llms in law. *arXiv preprint arXiv:2502.17638*, 2025.
- [64] Ismail Kovvuru. Replit ai deletes production database: 2025 devops security lessons for aws engineers. <https://medium.com/@ismailkovvuru/replit-ai-deletes-production-database-2025-devops-security-lessons-for-aws-engineers-4984c6e7a73d>.
- [65] LangChain. Langchain. <https://github.com/langchain-ai/langchain>, 2026.
- [66] Ninghui Li, Haining Chen, and Elisa Bertino. On practical specification and enforcement of obligations. In *Proceedings of the second ACM conference on Data and Application Security and Privacy*, pages 71–82, 2012.
- [67] Zekun Li, Shinda Huang, Jiangtian Wang, Nathan Zhang, Antonis Antoniadis, Wenyue Hua, Kaijie Zhu, Sirui Zeng, William Yang Wang, and Xifeng Yan. Sopbench: Evaluating language agents at following standard operating procedures and constraints. *arXiv preprint arXiv:2503.08669*, 2025.
- [68] Sijia Liu, Yang Liu, and Nathalie Baracaldo. *Machine Unlearning for Governance of Foundation Models*. Springer, 2026.
- [69] Sijia Liu, Yuanshun Yao, Jinghan Jia, Stephen Casper, Nathalie Baracaldo, Peter Hase, Xiaojun Xu, Yuguang Yao, Hang Li, Kush R Varshney, et al. Rethinking machine unlearning for large language models. *arXiv preprint arXiv:2402.08787*, 2024.
- [70] Yupei Liu, Yuqi Jia, Rumpeng Geng, Jinyuan Jia, and Neil Zhenqiang Gong. Formalizing and benchmarking prompt injection attacks and defenses. In *33rd USENIX Security Symposium (USENIX Security 24)*, pages 1831–1847, 2024.

- [71] Weidi Luo, Shenghong Dai, Xiaogeng Liu, Suman Banerjee, Huan Sun, Muhao Chen, and Chaowei Xiao. Agrail: A lifelong agent guardrail with effective and adaptive safety detection. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 8104–8139, 2025.
- [72] Conor McCauley, Zeliang Kan, and Jason Martin. IH-BENCHMARK: A conflict-centered benchmark for instruction-hierarchy robustness in llm applications. *arXiv preprint arXiv:2607.25987*, 2026.
- [73] METR. Brief independent investigation of agents’ behavior, reasoning and collaboration in the openai / hugging face hacking incident. <https://metr.org/blog/2026-08-26-openai-hugging-face-incident-investigation/>, 08 2026.
- [74] Jared Moore, Ashish Mehta, William Agnew, Jacy Reese Anthis, Ryan Louie, Yifan Mai, Peggy Yin, Myra Cheng, Samuel J Paech, Kevin Klyman, Stevie Chancellor, Eric Lin, Nick Haber, and Desmond C. Ong. Characterizing delusional spirals through human-llm chat logs, 2026.
- [75] Open Claw. Open claw. <https://openclaw.ai>, 2026.
- [76] OpenAI. Memory faq. <https://help.openai.com/en/articles/8590148-memory-faq>, 2026.
- [77] OWASP. Owasp top 10 for large language model applications, 2025.
- [78] Inkit Padhi, Manish Nagireddy, Giandomenico Cornacchia, Subhajit Chaudhury, Tejaswini Pedapati, Pierre Dognin, Keerthiram Murugesan, Erik Miehl, Martín Santillán Cooper, Kieran Fraser, Giulio Zizzo, Muhammad Zaid Hameed, Mark Purcell, Michael Desmond, Qian Pan, Zahra Ashktorab, Inge Vejsbjerg, Elizabeth M. Daly, Michael Hind, Werner Geyer, Ambrish Rawat, Kush R. Varshney, and Prasanna Sattigeri. Granite guardian. <https://arxiv.org/abs/2412.07724>, 2024.
- [79] Melissa Z Pan, Negar Arabzadeh, Riccardo Cogo, Yuxuan Zhu, Alexander Xiong, Lakshya A Agrawal, Huanzhi Mao, Emma Shen, Sid Pallerla, Liana Patel, et al. Measuring agents in production. *arXiv preprint arXiv:2512.04123*, 2025.
- [80] Nina Panickssery, Nick Gabrieli, Julian Schulz, Meg Tong, Evan Hubinger, and Alexander Matt Turner. Steering llama 2 via contrastive activation addition. *arXiv preprint arXiv:2312.06681*, 2023.
- [81] Siani Pearson and Andrew Charlesworth. Accountability as a way forward for privacy protection in the cloud. In *IEEE international conference on cloud computing*, pages 131–144. Springer, 2009.

- [82] Rafael Rafailov, Archit Sharma, Eric Mitchell, Christopher D Manning, Stefano Ermon, and Chelsea Finn. Direct preference optimization: Your language model is secretly a reward model. *Advances in neural information processing systems*, 36:53728–53741, 2023.
- [83] Zixin Rao, Wentian Zhu, Chan Aristella Lu, Zhaorun Chen, Wei Niu, Le Guan, Bo Li, and Zhen Xiang. Fragfuse: Bypassing access control of large language model agents via memory-based query fragmentation and fusion. *arXiv preprint arXiv:2606.15609*, 2026.
- [84] Traian Rebedea, Razvan Dinu, Makesh Narsimhan Sreedhar, Christopher Parisien, and Jonathan Cohen. Nemo guardrails: A toolkit for controllable and safe llm applications with programmable rails. In *Proceedings of the 2023 conference on empirical methods in natural language processing: system demonstrations*, pages 431–445, 2023.
- [85] Red Hat. The uncomfortable truth about vibe coding. <https://developers.redhat.com/articles/2026/02/17/uncomfortable-truth-about-vibe-coding>, 2026.
- [86] Arion Research. Conflict resolution playbook: When agents (and organizations) clash. <https://www.arionresearch.com/blog/conflict-resolution-playbook>, 2025.
- [87] Shir Rozenfeld, Rahul Pankajakshan, Itay Zloczower, Eyal Lenga, Gilad Gressel, and Yisroel Mirsky. Gavel: Towards rule-based safety through activation monitoring. *arXiv preprint arXiv:2601.19768*, 2026.
- [88] Fred B Schneider. Enforceable security policies. *ACM Transactions on Information and System Security (TISSEC)*, 3(1):30–50, 2000.
- [89] Basit Shafiq, James BD Joshi, Elisa Bertino, and Arif Ghafoor. Secure interoperation in a multidomain environment employing rbac policies. *IEEE transactions on knowledge and data engineering*, 17(11):1557–1577, 2005.
- [90] Zhihong Shao, Peiyi Wang, Qihao Zhu, Runxin Xu, Junxiao Song, Xiao Bi, Haowei Zhang, Mingchuan Zhang, YK Li, Y Wu, et al. Deepseekmath: Pushing the limits of mathematical reasoning in open language models, 2024. *arXiv preprint arXiv:2402.03300*, 2(3):5, 2024.
- [91] Lillian Tsai and Eugene Bagdasarian. Contextual agent security: A policy for every purpose. In *Proceedings of the 2025 Workshop on Hot Topics in Operating Systems*, pages 8–17, 2025.
- [92] U.S. Department of Health and Human Services. The health insurance portability and accountability act (hipaa), 1996.
- [93] Paul Voigt and Axel Von dem Bussche. The eu general data protection regulation (gdpr). *A Practical Guide, 1st Ed., Cham: Springer International Publishing*, 10(3152676):10–5555, 2017.

- [94] Changsheng Wang, Chongyu Fan, Yihua Zhang, Jinghan Jia, Dennis Wei, Parikshit Ram, Nathalie Baracaldo, and Sijia Liu. Rethinking unlearning for large reasoning models. In *ICML 2025 Workshop on Machine Unlearning for Generative AI*, 2025.
- [95] Changsheng Wang, Yihua Zhang, Jinghan Jia, Parikshit Ram, Dennis Wei, Yuguang Yao, Soumyadeep Pal, Nathalie Baracaldo, and Sijia Liu. Invariance makes llm unlearning resilient even to unanticipated downstream fine-tuning. *arXiv preprint arXiv:2506.01339*, 2025.
- [96] Lei Wang, Chen Ma, Xueyang Feng, Zeyu Zhang, Hao Yang, Jingsen Zhang, Zhiyuan Chen, Jiakai Tang, Xu Chen, Yankai Lin, et al. A survey on large language model based autonomous agents. *Frontiers of Computer Science*, 18(6):186345, 2024.
- [97] Peiran Wang, Ying Li, and Yuan Tian. Aligning provenance with authorization: A dual-graph defense for llm agents. *arXiv preprint arXiv:2605.26497*, 2026.
- [98] Xinran Wang, Qi Le, Ammar Ahmed, Enmao Diao, Yi Zhou, Nathalie Baracaldo, Jie Ding, and Ali Anwar. Map: Multi-human-value alignment palette. *arXiv preprint arXiv:2410.19198*, 2024.
- [99] Wikipedia. Swiss cheese model. https://en.wikipedia.org/wiki/Swiss_cheese_model, 2026.
- [100] Herbert Woisetschlager, Ryan Zhang, Shiqiang Wang, and Hans Arno Jacobsen. Mess+: Dynamically learned inference-time llm routing in model zoos with service level guarantees. *Advances in Neural Information Processing Systems*, 38:54034–54067, 2026.
- [101] Cameron Wolfe. Understanding and using supervised fine-tuning (sft) for language models, 2023.
- [102] Chris Wright, Crispin Cowan, Stephen Smalley, James Morris, and Greg Kroah-Hartman. Linux security modules: General security support for the linux kernel. In *11th USENIX security symposium (USENIX Security 02)*, 2002.
- [103] Zhiheng Xi, Wenxiang Chen, Xin Guo, Wei He, Yiwen Ding, Boyang Hong, Ming Zhang, Junzhe Wang, Senjie Jin, Enyu Zhou, et al. The rise and potential of large language model based agents: A survey. *Science China Information Sciences*, 68(2):121101, 2025.
- [104] Zhen Xiang, Linzhi Zheng, Yanjie Li, Junyuan Hong, Qinbin Li, Han Xie, Jiawei Zhang, Zidi Xiong, Chulin Xie, Carl Yang, et al. Guardagent: Safeguard llm agents via knowledge-enabled reasoning. In *Forty-second International Conference on Machine Learning*, 2024.

- [105] Shunyu Yao, Noah Shinn, Pedram Razavi, and Karthik Narasimhan. τ -bench: A benchmark for tool-agent-user interaction in real-world domains. *arXiv preprint arXiv:2406.12045*, 2024.
- [106] Yi Zeng, Yu Yang, Andy Zhou, Jeffrey Ziwei Tan, Yuheng Tu, Yifan Mai, Kevin Klyman, Minzhou Pan, Ruoxi Jia, Dawn Song, et al. Air-bench 2024: A safety benchmark based on risk categories from regulations and policies. *arXiv preprint arXiv:2407.17436*, 2024.
- [107] Naama Zwerdling, David Boaz, Ella Rabinovich, Guy Uziel, David Amid, and Ateret Anaby Tavor. Towards enforcing company policy adherence in agentic workflows. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing: Industry Track*, pages 595–606, 2025.